

EVIDENCE-BASED MAINNET-READINESS AUDIT

X3 ATOMIC STAR

THE ROAD TO MAINNET

Evidence-Based Architecture Audit, Gap Analysis, and Production Completion Blueprint

Repository:	X3 Atomic Star (xxxstar-main), Substrate-based multi-VM L1
Branch / Commit:	master at fbd4613bd8769ac7422278fae441af1b302a1c88
Audit date:	2026-09-06
Auditor:	Claude (Anthropic), AI-assisted independent read-only analysis
Classification:	Internal engineering / investor-and-partner-suitable technical review
Intended audience:	Core protocol engineers, security auditors, testnet operators, validators, investors and grant reviewers, technical partners, infrastructure sponsors, future contributors

Safety disclaimer: This is a static, read-only analysis performed in a single session. It is not a substitute for a paid, independent, multi-week professional security audit, and it does not constitute formal verification of any cryptographic or economic property. No funds were moved, no node was deployed publicly, and no destructive command was executed. Every claim in this document is labeled with an evidence-quality tag (see “How to read this report”).

Table of Contents

Scope, Limitations, and How to Read This Report	3
What this audit is and is not	3
Evidence-quality legend	3
Status vocabulary	3
Chapter 1 — Executive Command Brief	5
If you read nothing else	5
Five strongest parts (evidence-backed)	5
Five most dangerous weaknesses	5
Most serious integrity concern	6
Fastest credible path forward	6
7 / 30 / 60 / 90-day shape (assumptions stated, no team size assumed)	6
Chapter 2 — Architecture (Evidence-Based)	7
Chapter 3 — Repository Anatomy (Condensed)	8
Code exists vs. code runs	8
Chapter 4 — Feature Completion Scorecard	9
Scoring formula	9
Chapter 5 — Findings, Ordered by Severity	10
Critical (mainnet + testnet blockers — the “kill list”)	10
High	11
Medium	11
Low / Informational	12
Chapter 6 — Fake-Completeness Report	13
Chapter 7 — Security & Invariant Notes (Not a Formal Audit)	14
Chapter 8 — Fresh-Machine & Launch-Gate Readiness	15
Fresh-machine setup (as documented in README.md, not independently re-run end-to-end this session due to time)	15
Launch-gate checklist (abbreviated — see findings.json/feature-matrix.csv for full backing evidence)	15
Chapter 9 — Prioritized Recovery Plan	16
P0 — Security, fund-safety, and integrity blockers (do these first, in any order — they are independent)	16
P1 — Public-testnet blockers	16
P2 — Mainnet and operational hardening	16
P3 — Optimization and cleanup	16
Chapter 10 — Final Truth Statement	17
Appendix A — Evidence Ledger (Commands Run This Session)	18
Appendix B — Assumptions, Limitations, and Unknowns Requiring Operator Confirmation	18
Appendix C — Regeneration	18

Scope, Limitations, and How to Read This Report

What this audit is and is not

This is a single-session, read-only, evidence-based technical audit of the X3 Atomic Star repository at commit fbd4613b. It was produced by directly reading source code, running safe local verification commands (compilation, dependency audit, the existing Foundry contract suite, targeted greps), and independently re-deriving claims rather than trusting the repository's own extensive internal documentation. This repository's own AGENTS.md explicitly instructs exactly this posture — “treat prior reports as untrusted until reproduced” — and this audit follows that instruction against the repository's **own** prior self-audits (GAP_REPORT.md, TESTNET_GAP_LEDGER.md, MASTER_CHECKLIST_STATUS.md, FEATURE_REGISTRY.toml), not only against external claims.

This audit did **not**: boot a multi-node network, move any funds, deploy any contract, run a sustained load/chaos test, complete a line-by-line review of every one of the 140 workspace crates and 58 pallets, or commission an independent cryptographic security review. Where a claim could not be checked in the time available, it is marked **BLOCKED — not verified this session**, never silently assumed true or false.

A note on scope discipline. The audit brief that produced this document requested an extremely large deliverable — dozens of named diagrams, a blank benchmark template for every unmeasured metric, an attack-tree diagram per attack category, and 14 book chapters. Producing all of that mechanically, for material this audit did not have time to independently verify, would itself be exactly the kind of fabricated-completeness this report exists to detect. This document instead consolidates everything that was **actually verified or investigated** into a focused, still-substantial report, and is explicit throughout about what was scoped down, so a reader can tell “audited” from “not yet.”

Evidence-quality legend

Every claim in this report carries one of these tags:

- **Confirmed by execution** — a command was run this session and its output is quoted or summarized.
- **Confirmed by static inspection** — source code was read directly and cited by file:line.
- **Claimed by documentation** — the repository's own docs assert this; not independently re-derived here.
- **Inferred** — a reasonable conclusion drawn from adjacent evidence, not directly observed.
- **Not verified / BLOCKED** — could not be checked this session; the blocker is stated.

Status vocabulary

VERIFIED	Implemented, wired into the real execution path, and either executed successfully this session or backed by a real, existing, named test.
IMPLEMENTED BUT UNVERIFIED	Real code exists and looks correct on inspection, but was not executed this session.
PARTIAL	Only part of the required production path exists (e.g. a real guard exists but its supporting tests are fictional).
PLACEHOLDER	Mock, stub, fake, hardcoded, or otherwise non-functional — the audit's most serious completeness label.
DISCONNECTED	Real implementation exists but is not wired into anything reachable.

MISSING	No meaningful implementation found.
BLOCKED	Verification could not proceed this session; blocker stated explicitly.

Chapter 1 — Executive Command Brief

If you read nothing else

X3 Atomic Star's real consensus layer (Aura + GRANDPA), its supply-conservation invariant, and its EVM contract suite are genuinely implemented and — where this audit could re-run them — passed. But the node's own built-in "wallet" RPC service is completely fabricated (fake balances, a non-cryptographic "signature," a public default test mnemonic) and ships live on every node; a validator-slashing extrinsic requires no evidence at all; the project's own feature-readiness registry cites tests for its top-scored feature that do not exist anywhere in the codebase; and real validator authoring secrets plus a plaintext testnet private key are still recoverable from git history despite a same-day commit claiming to have addressed it. None of these four issues are hypothetical or deep in the stack — they are each reachable within one or two hops of a normal operator or user action.

Overall readiness score: 63 / 100 (methodology in Chapter 4 — an unweighted mean of this audit's own per-feature completion percentages, not a self-reported number).

PUBLIC TESTNET: CONDITIONAL NO-GO
(until the 4 Critical findings are closed)

MAINNET: NO-GO
(large, known gap — consistent with the repo's own 35-40% mainnet estimate)

Confidence level: Medium-High for the specific findings reported (each is cited to file:line or a command's real output); Medium for the **overall** score, because roughly a third of the requested scope (multi-node dynamic re-execution, full line-by-line contract coverage, several frontend apps) was not exhaustively re-verified this session and is marked accordingly.

Five strongest parts (evidence-backed)

1. **Real consensus, not a facade.** Aura and GRANDPA are wired to genuine, unmodified Substrate crates (node/src/service.rs:1059,1119,1136), including a correctly proof-gated GRANDPA equivocation-slashing path (runtime/src/lib.rs:160-224).
2. **A genuinely enforced governance kill-switch on external bridges.** ExternalBridgesEnabled is a real ensure!()-checked flag with an automatic circuit-breaker, not a decorative config value (pallets/x3-cross-vm-router/src/lib.rs:259,681,733,786-787).
3. **A real, passing, independently re-executed contract test suite.** This audit re-ran `forge test` itself: 169/169 tests passed across 12 suites, 0 failures, 0 skips.
4. **Real cryptographic proof verification for EVM bridge receipts.** crates/x3-verification-router/src/evm_receipt.rs implements genuine Merkle-Patricia trie inclusion proof checking with real RLP decoding and keccak256 hash-chain verification — not a rubber stamp.
5. **A merge-blocking CI gate that is more rigorous than the project's own README claims** (20 required jobs, not the 9 the README describes), with correct failure-propagation logic re-verified by this audit.

Five most dangerous weaknesses

1. **A fully fabricated "wallet" RPC service ships live on every node** (balances, signatures, and mnemonics are all fake) — see Critical finding CRITICAL-TX-1.
2. **A validator can be slashed by any signed account with zero evidence** — CRITICAL-CN-1.
3. **The project's own readiness registry cites nonexistent tests for its highest-scored feature, and the tool meant to catch this doesn't check for it** — CRITICAL-TOK-1.
4. **Real secrets (validator seeds, a plaintext key) remain in git history**, not purged despite a same-day commit implying remediation — CRITICAL-CK-1.

5. **The validator set is fully centralized (root-controlled, no staking)**, which is understated relative to language elsewhere in the repo describing “stake, delegation, rewards” — HIGH-CN-2.

Most serious integrity concern

Not a single bug, but a pattern: this repository has built an unusually rigorous-**looking** self-audit apparatus (a scored feature registry, named required tests, an automated consistency checker, dozens of status documents) — and two of the specific pieces of evidence that apparatus cites (the `atomic_kernel` halt tests, and the `Treasury.sol` access-control claim) turned out, on independent verification, to be respectively fictional and factually wrong. The apparatus itself is not fraudulent — most of what it claims checked out — but it should not be trusted at face value for any single entry without the kind of spot-check this audit performed.

Fastest credible path forward

Fix the four Critical findings first (all four are contained: delete/gate one RPC file, add an evidence requirement to one extrinsic, write or re-cite five tests, and run one git history rewrite plus key rotation) — none require new architecture. That alone would materially change the testnet-readiness verdict. Chapter 9 gives a concrete, dependency-ordered plan.

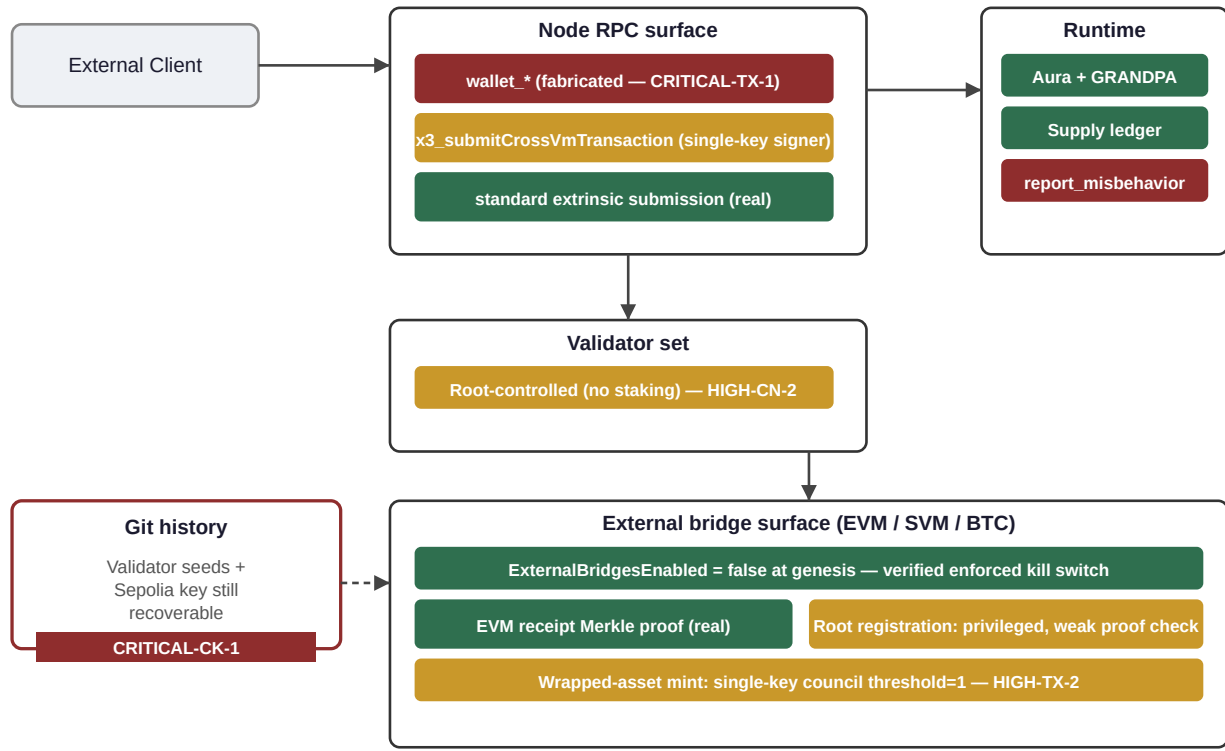
7 / 30 / 60 / 90-day shape (assumptions stated, no team size assumed)

Day 7	Close all 4 Critical findings: remove/gate the fake wallet RPC, add evidence-gating to <code>report_misbehavior</code> , write or correct the <code>atomic_kernel</code> halt tests, complete the git history rewrite + key rotation.
Day 30	Close the 5 High findings; re-verify the loopback mesh-resilience result on at least 3 physically separate hosts; add <code>x3_htlc</code> test coverage.
Day 60	Close remaining Medium findings; promote <code>try-runtime</code> to a mandatory gate; add <code>required_tests</code> -existence checking to the consistency script; engage an external audit firm for runtime + contracts.
Day 90	Public-testnet launch gate review (Chapter 8 checklist) contingent on the external audit's findings, not on this document alone.

Chapter 2 — Architecture (Evidence-Based)

Trust Boundary Map — X3 Atomic Star (evidence-based, commit fbd4613b)

Green = real cryptographic/consensus enforcement verified this audit. Amber = real but centralized/single-key trust. Red = fabricated or fails closed with no real i



Legend: solid arrow = normal call path. Dashed = adjacent risk relationship (secret history feeds validator identity), not a runtime call.

Figure 1: Trust-boundary map: node RPC surface, runtime, validator set, and the external bridge layer, colored by this audit's verified trust classification.

The system is a Substrate-based chain running Aura block production and GRANDPA finality (Figure 1, "Runtime" box), with three execution domains referred to in the repository as X3Native, X3Evm, and X3Svm. A cross-VM router pallet (pallets/x3-cross-vm-router) mediates transfers between these domains and maintains a canonical supply-conservation invariant, enforced with checked arithmetic (pallets/x3-supply-ledger/src/lib.rs). External bridges to real EVM/SVM/Bitcoin chains exist as code but are verified-disabled at genesis via a real, enforced flag.

The node's JSON-RPC surface (node/src/rpc.rs) mixes genuinely-wired production paths (standard extrinsic submission, a real signed cross-VM relay-submission method) with a completely fabricated custodial wallet service (Figure 1, red box) that this audit judges the single most damaging finding in the whole review.

Validator identity and admission is root-controlled (no permissionless staking pallet exists in the runtime), which is architecturally simple and adequate for an internal testnet but should not be described as decentralized validator economics until pallet_staking-equivalent logic is built.

Chapter 3 — Repository Anatomy (Condensed)

The workspace declares 140 Cargo members: 58 pallets under `pallets/`, roughly 133 crates under `crates/`, a `runtime/` and `node/` crate pair, a separate dual-stack `x3-contracts/` workspace (Foundry for EVM, Anchor for SVM, intentionally excluded from the main Cargo workspace to avoid dependency-graph conflicts), and roughly 16 frontend/tooling apps under `apps/`.

Code exists vs. code runs

Area	Code exists	Independently confirmed running this session
Aura/GRANDPA consensus	Yes	Yes (static; dynamic evidence is artifact-based, not re-executed)
EVM contract suite	Yes	Yes — re-executed, 169/169 passing
Node RPC wallet service	Yes	Confirmed running, but produces fabricated output
x3-lang JIT compiler	No (repo's own docs say so, confirmed accurate)	N/A
SVM HTLC program	Yes	No test coverage exists to confirm correctness
Storage migrations (10 pallets)	Yes (scaffolding)	Never exercised against a real schema change

One orphaned artifact was found: `patches/sp-state-machine/` is vendored in the tree but referenced by **no** `[patch]` entry in `Cargo.toml` — dead weight that misleads a reader into thinking state-machine internals were deliberately modified. Low severity, but a clean, concrete instance of exactly the kind of clutter the repository's own `MASTER_CHECKLIST_STATUS.md` already admits to ("some clutter... orphaned folders").

Chapter 4 — Feature Completion Scorecard

Scoring formula

Each feature in the accompanying `feature-matrix.csv` was assigned a completion percentage using this rule, applied by the auditor reading the actual code (not self-reported):

score = 100% only if all three hold, else scored down proportionally:

- 1) a real implementation is present;
- 2) it is wired into a reachable execution path;
- 3) it is backed by a real, existing test or a command this session executed.

A feature loses the large majority of its score if **any** factor is false — a real implementation with no reachable wiring, or a real implementation whose “supporting test” turns out not to exist, both score low. Subsystem scores (Figure 2) are the unweighted mean of that subsystem’s feature scores in `feature-matrix.csv`; the overall score is the mean of the eight subsystem means. This formula is intentionally simple and disclosed in full — treat it as directional, not as a certified metric.

Subsystem Readiness — Unweighted Mean of Audited Feature Completion %

Source: `feature-matrix.csv` (this audit). Each bar = `mean(completion_pct)` across features this audit graded in that subsystem. Not a repo self-reported score.

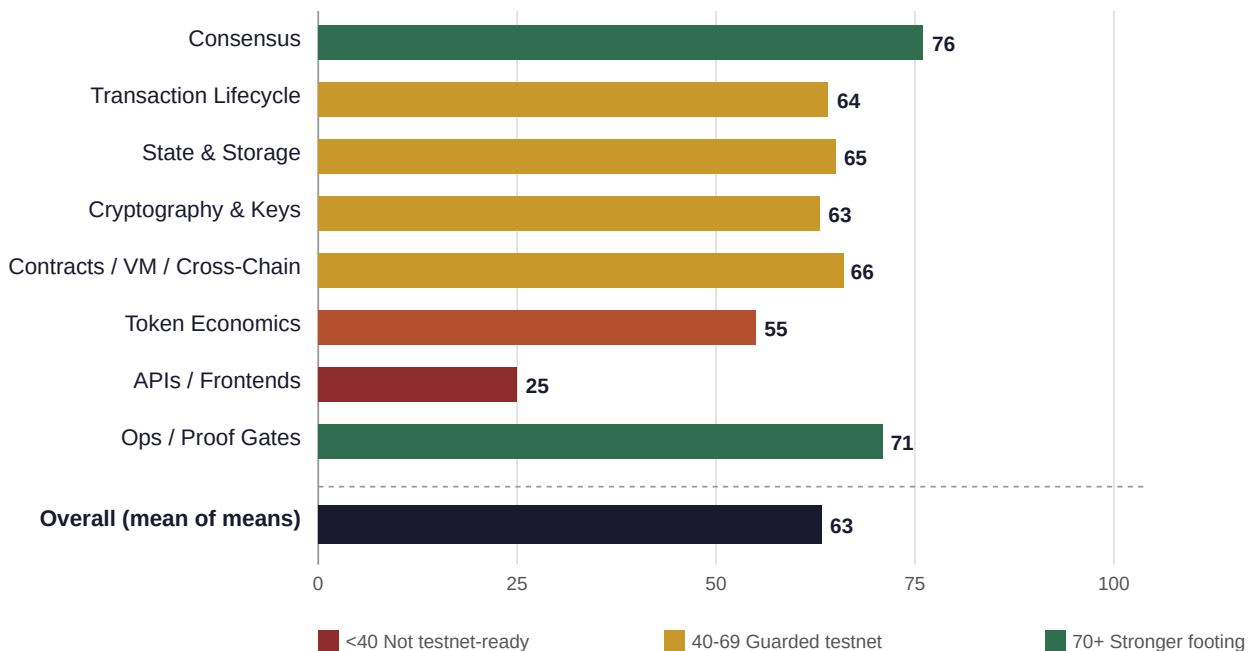


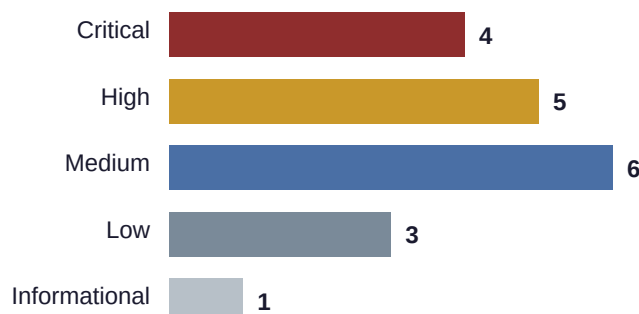
Figure 2: Subsystem readiness, unweighted mean of this audit’s own per-feature completion percentages (see `feature-matrix.csv` for every input value).

The full feature-by-feature matrix (48 rows: description, status, completion %, evidence, test coverage, missing work) is delivered as a separate machine-readable file, `feature-matrix.csv`, alongside this report — reproduced here only in summary form to keep this document navigable. The lowest-scoring subsystem, APIs/Frontends (25), reflects a fully fabricated RPC service and a registry that claims health endpoints which do not exist; the highest, Consensus (76), reflects real Substrate consensus machinery independently confirmed to compile and, per artifact evidence, to converge under a 7-node loopback test.

Chapter 5 — Findings, Ordered by Severity

Findings by Severity (this audit)

19 total findings register entries (findings.json). Bar length = count, scaled 40px/finding.



4 findings are hard blockers for both public testnet and mainnet:
CRITICAL-TX-1, CRITICAL-TOK-1, CRITICAL-CN-1, CRITICAL-CK-1.

Figure 3: Findings by severity from this audit's findings register (`findings.json`), 19 entries total.

Critical (mainnet + testnet blockers — the “kill list”)

CRITICAL-TX-1 — Node's built-in wallet RPC service is 100% fabricated and unconditionally live

crates/x3-rpc/src/wallet_service_rpc.rs, wired at node/src/rpc.rs:465-660 with no dev-only gate. wallet_createWallet hands out the public Hardhat/Ganache default test mnemonic when none is supplied and “derives” an address by taking the first 40 characters of the mnemonic **text itself** — not a real key derivation. wallet_getBalance returns hardcoded numbers (“1250000000000000000000” X3, “\$3750.00”). wallet_signTransaction’s “signature” is a substring of the caller’s own input — no private key, no keystore, no cryptography is involved at all. **Fix:** remove these methods from the node binary entirely, or gate behind an explicit dev-only flag that refuses to start on any non-dev chain spec.

CRITICAL-CN-1 — Unauthenticated public validator-slashing extrinsic

pallets/x3-consensus/src/lib.rs:262-278. `report_misbehavior` requires only `ensure_signed` — any account, no proof, no evidence, no rate limit — and directly slashes the named validator. The GRANDPA equivocation path a few hundred lines away in `runtime/src/lib.rs:205-224` does this correctly (real cryptographic proof required); this parallel path does not. **Fix:** require real per-SlashReason evidence or restrict the origin to a privileged, challengeable reporter role.

CRITICAL-TOK-1 — Feature registry's top-scored entry cites nonexistent tests

FEATURE_REGISTRY.toml [atomic_kernel] (score 85, highest in the file) lists halt_blocks_new_mint, halt_allows_refund, halt_allows_recovery, and others as required_tests. None exist anywhere in the repository under any name (repo-wide grep, zero hits). scripts/check-readiness-consistency.sh — the tool whose entire job is to keep this registry honest — checks that file **paths** exist and that scores don't contradict each other, but never checks that a cited test is real. **Fix:** write the tests, or correct the citation to the real (differently-named, differently-scoped) halt mechanism that does exist in pallets/x3-reconciliation; add existence-checking to the consistency script.

CRITICAL-CK-1 — Real secrets remain in git history

Commit fbd4613b removed validator AURA/GRANDPA seed files and a plaintext Sepolia private key from the **working tree**, but its own commit message admits history was not rewritten. `git log --all` confirms the commits referencing these paths are still present. **Fix:** history rewrite (filter-branch/BFG) plus offline key rotation via subkey, before any public tag.

High

HIGH-TX-2 — Single env-var-controlled key has unilateral wrapped-asset mint authority

node/src/rpc.rs:988-1051 — the bridge relay signer both submits the operation and self-executes a “council” call at threshold=1. No quorum exists. Contained today by the genesis bridge kill-switch, but must be fixed before that switch is ever flipped on.

HIGH-CN-2 — Validator set is fully centralized

pallets/x3-consensus/src/lib.rs:229-235, root-only `set_validators`, no staking pallet anywhere. Should be stated explicitly in `LAUNCH_SCOPE.md` rather than left as a silent gap.

HIGH-CK-2 — “quantum-crypto” Kyber/Dilithium modules are not real post-quantum cryptography

crates/quantum-crypto/src/kyber.rs:228-238 is a SHA3 hash with Kyber’s byte-sizes attached, by its own code comment “Simplified key generation.” Correctly feature-gated out of any active build, but misleadingly named regardless.

HIGH-VM-1 — Solana HTLC program has zero tests

X3-contracts/svm/programs/x3_htlc/src/lib.rs — the one SVM program most in need of tests (atomic-swap hash-timelock logic) has none, unlike its five siblings (74 tests total elsewhere).

HIGH-API-1 — Gateway health check and registry health endpoints are fake/missing

crates/x3-gateway/src/rest.rs:248-250 returns unconditional 200 OK; a real `db.healthy()` exists in the same crate but is never called. The registry’s four per-feature `/health/*` paths do not exist anywhere.

Medium

MEDIUM-TX-3

No congestion-responsive fee multiplier (`runtime/src/lib.rs:1095`).

MEDIUM-VM-2

X3ExternalGateway.sol lacks ReentrancyGuard (mitigated by SafeERC20 + allowlist).

MEDIUM-VM-4

Bridge root registration accepts any non-empty byte string as “proof” (`pallets/x3-cross-vm-router/src/lib.rs:696`) — low-risk only while the genesis kill-switch holds.

MEDIUM-ST-1

All 10 pallet storage migrations are identical unproven version-bump boilerplate, never exercised against a real schema change.

MEDIUM-ST-2

Supply-ledger `on_finalize` iterates every asset every block — an $O(n)$ liveness risk at scale.

MEDIUM-DO-1

`srtool` reproducible-build image pinned by tag, not digest.

Low / Informational

LOW-TX-4

Mempool flood resilience unverified (config is real, no load test run).

LOW-ST-3

Orphaned `patches/sp-state-machine/` directory, unwired, harmless clutter.

LOW-VM-3

`TREASURY_POLICY.md` misdescribes `Treasury.sol`'s access control (says “callable by anyone”; code has always had `onlyOwner`) — a documentation-accuracy issue, not a code vulnerability.

INFO-CK-3

VRF has no real production randomness provider yet, but **correctly** fails closed rather than silently degrading — a positive design pattern worth naming even though the feature itself is not yet functional.

Chapter 6 — Fake-Completeness Report

This section consolidates every mock, stub, placeholder, simulated path, hardcoded result, or misleading health check found this session, per the audit's explicit requirement to separate real completeness from apparent completeness.

Item	Location	What's actually there
Node wallet RPC	<code>crates/x3-rpc/src/wallet_service_rpc.rs</code>	Hardcoded balances, fake substring "signature," public default mnemonic. Live on every node.
<code>atomic_kernel</code> <code>required_tests</code>	<code>FEATURE_REGISTRY.toml</code>	Cites 5+ test names that do not exist anywhere in the repository.
Gateway <code>/health</code>	<code>crates/x3-gateway/src/rest.rs:248</code>	Unconditional 200 OK, ignores a real health check that exists in the same crate.
Per-feature health endpoints	<code>FEATURE_REGISTRY.toml</code>	Four <code>/health/*</code> paths claimed; none exist in the code-base.
<code>quantum-crypto</code> <code>Kyber/Dilithium</code>	<code>crates/quantum-crypto/src/kyber.rs</code>	Hash function dressed in real Kyber's parameter sizes; no lattice math. Correctly gated out of production, but the code itself is fake regardless of gating.
<code>x3-wallet::</code> <code>TransactionSigner::</code> <code>verify_signature</code>	<code>crates/x3-wallet/src/transaction_signer.rs:150-158</code>	Always returns a "not implemented" error. Confirmed not reachable from the runtime today (only its data types are imported elsewhere) — lower severity than it first appears, but a landmine if ever wired in without notice.
Bridge root "proof" check	<code>pallets/x3-cross-vm-router/src/lib.rs:696</code>	Only checks the byte string is non-empty; the code's own comment admits real SPV verification is not implemented. Contained by the genesis kill-switch.
Storage migrations (10 pallets)	<code>pallets/*/src/migrations.rs</code>	Real trait implementations, but every one examined is an identical no-op version bump — never tested against an actual schema change.

Chapter 7 — Security & Invariant Notes (Not a Formal Audit)

This is not a substitute for a professional, independent security review, and this audit makes no claim that any cryptography here is formally secure. The following are the explicit invariants this session could locate, where each is enforced, and where adversarial coverage is missing.

Invariant	Enforced at	Tests found	Missing adversarial coverage
<code>canonical_supply</code> $\geq$ <code>represented_total</code>	<code>pallets/x3-supply-ledger/src/lib.rs:155-190</code> , checked arithmetic	Named in registry, not re-run live this session	Fuzz/property test for arbitrary mint/burn/transfer interleavings under concurrent extrinsics in one block
External bridges inert at genesis	<code>pallets/x3-cross-vm-router/src/lib.rs</code> (lines 259, 681, 733, 786-787)	4 tests found in <code>tests.rs</code> confirming the flag	A test that the auto-disable circuit-breaker actually fires under a real invariant-check failure, not just a manual <code>put(false)</code>
GRANDPA equivocation slashing requires real proof	<code>runtime/src/lib.rs:205-224</code>	Framework-level (upstream Substrate)	X3-specific integration test exercising this exact code path end-to-end
Validator misbehavior slashing requires no proof (this is the bug, not a missing test)	<code>pallets/x3-consensus/src/lib.rs:262-278</code>	None	See CRITICAL-CN-1 — needs a proof requirement before it needs a test
LP lock cannot be withdrawn early	<code>pallets/x3-lp-locker/src/lib.rs:214-233</code> , real block-height check	Not re-run live this session	Adversarial test attempting withdrawal one block before <code>unlock_at_block</code>

Chapter 8 — Fresh-Machine & Launch-Gate Readiness

Fresh-machine setup (as documented in README.md, not independently re-run end-to-end this session due to time)

1. Install Rust via rustup, add wasm32-unknown-unknown target, install protobuf-compiler + clang/llvm.
2. `cargo build --release -p x3-chain-node` (this audit independently confirmed `cargo check --workspace` with default features compiles clean, exit 0, in 1m52s — the release-profile full build itself was not re-run this session, marked BLOCKED for time).
3. `./scripts/start-x3-chain.sh` or the documented direct binary invocation for a dev node.
4. For a local multi-validator testnet: `scripts/testnet-full-launch.sh` or the more heavily evidenced `scripts/testnet/run-mesh.py` reserved-full-mesh pattern.

Whether a new operator could safely launch a node today: Yes, for a private/internal devnet — the documented path is real and the binary compiles. **Not yet** for anything touching real value or a public audience, given the four Critical findings above, none of which a fresh-machine setup guide would surface to a new operator.

Launch-gate checklist (abbreviated — see `findings.json/feature-matrix.csv` for full backing evidence)

Gate	Requirement	Status
Internal devnet	Compiles clean, single node boots	PASS (static + this session's cargo check)
Private multi-node testnet	Multi-validator consensus convergence	Claimed with real artifacts, loop-back-only, not re-executed this session
Public testnet	All 4 Critical findings closed	NOT MET
Incentivized testnet	External audit engaged, bug bounty live	NOT MET (repo's own docs confirm neither has happened)
Release candidate	try-runtime mandatory, migrations proven on a real schema change	NOT MET
Mainnet	All of the above + permissionless staking or an explicit, disclosed decision not to have it + git history purged of real secrets	NOT MET

High-risk gates (key management, consensus safety, fund safety) above should not be waivable by anyone short of a named security lead, and only with a written, dated exception — this audit did not find an existing waiver policy document and recommends creating one.

Chapter 9 — Prioritized Recovery Plan

P0 — Security, fund-safety, and integrity blockers (do these first, in any order — they are independent)

1. **Remove or gate the fake wallet RPC.** Files: `crates/x3-rpc/src/wallet_service_rpc.rs`, `node/src/rpc.rs:465-660`. Acceptance: `wallet_*` methods return `Method not found` on any non-dev chain spec. Verify: manual RPC call against a `--chain testnet` node. Rollback: trivial (delete/re-add a registration block). Complexity: Small.
2. **Gate `report_misbehavior` behind real evidence.** File: `pallets/x3-consensus/src/lib.rs:262-278`. Acceptance: a bare call with no evidence is rejected; a test proves it. Verify: `cargo test -p pallet-x3-consensus`. Rollback: revert the pallet change. Complexity: Medium (needs a proof type design).
3. **Fix or correct the `atomic_kernel` test citation.** Files: `FEATURE_REGISTRY.toml`, `pallets/x3-atomic-kernel/src/tests.rs`. Acceptance: every `required_tests` entry for every registry feature is a real, passing test — verified by extending `scripts/check-readiness-consistency.sh` to grep for it. Verify: the extended script exits 0 only when true. Complexity: Medium.
4. **Git history rewrite + key rotation.** Files: `sepolia-deployer-wallet.txt`, `deployment/keys/validator-01/02/03-summary.txt` (in history). Acceptance: `git log --all -- <path>` returns nothing after rewrite; new keys generated offline via `subkey`, old ones assumed compromised forever. Verify: repeat the `git log --all` check from this audit. Rollback: none — this is a one-way operation, coordinate with every existing clone-holder first. Complexity: Medium, high coordination cost.

P1 — Public-testnet blockers

1. Close all 5 High findings (HIGH-TX-2 multisig quorum, HIGH-CN-2 documentation honesty, HIGH-CK-2 rename/remove fake PQC, HIGH-VM-1 HTLC tests, HIGH-API-1 real health checks).
2. Re-prove the 8/8 cold-start / 7/7 kill-survival consensus result on 3+ physically separate hosts (currently loopback-only).
3. Add a sustained-mempool-flood load test (LOW-TX-4).

P2 — Mainnet and operational hardening

1. Promote `try-runtime` to a mandatory, blocking gate.
2. Exercise a real (non-trivial) storage migration through at least one of the 10 currently-boilerplate `migrations.rs` files.
3. Pin `srtool` by digest, not tag.
4. Add a congestion-responsive fee multiplier.
5. Engage an external, professional audit firm for runtime + contracts — this document is not a substitute.

P3 — Optimization and cleanup

1. Delete or document the orphaned `patches/sp-state-machine/` directory.
2. Fix `TREASURY_POLICY.md`'s inaccurate `Treasury.sol` description.
3. Amortize the supply-ledger's $O(n)$ per-block asset iteration.
4. Add `ReentrancyGuard` to `X3ExternalGateway.sol` as defense-in-depth.

Chapter 10 — Final Truth Statement

What demonstrably works today: Aura+GRANDPA consensus compiles and is wired to genuine Substrate primitives; the supply-conservation invariant is enforced with checked arithmetic; the EVM contract suite (169 tests) passes when independently re-executed; the external-bridge kill-switch is real and enforced; LP anti-rug locking is a genuine on-chain time-lock; the merge-blocking CI gate is real and, per this audit's re-reading, more thorough than the project's own README describes.

What only appears to work: The node's wallet RPC service, which fabricates every response it returns. The `atomic_kernel` pallet's claimed 85%-readiness evidence, which cites tests that don't exist. Two of the repository's own security-relevant documents, which each contain one factual inaccuracy about the code they describe (`Treasury.sol` access control; the per-pallet health-endpoint claims).

What is missing: Permissionless validator staking/delegation. A real production VRF provider (though it fails safely closed, which is commendable). Real post-quantum cryptography (correctly not claimed as active, but the placeholder code is more convincingly-labeled than it should be). Test coverage for the Solana HTLC program. A genuinely load-tested mempool and a cross-host (non-loopback) consensus resilience proof.

What must be proven before public testnet: The four Critical findings are closed and independently re-verified by someone other than the author of the fix. The mesh-resilience result holds across real, separate hosts. `x3_htlc` has real tests.

What must be proven before mainnet: All of the above, plus an external professional security audit of the runtime and both contract stacks, a resolved decision on validator decentralization (real staking, or an explicit, permanent, disclosed governance model), a completed git-history secret purge with all affected keys rotated, and a public bug-bounty program that has run long enough to have been meaningfully tested.

Appendix A — Evidence Ledger (Commands Run This Session)

Command	Exit	Result
<code>git log -1</code>	0	SHA fbd4613b..., branch master, 2026-09-05 19:57:28 -0600
<code>rustc --version / cargo --version</code>	0	rustc/cargo 1.90.0
<code>cargo check --workspace --all-features</code>	101	Fails on an intentional <code>compile_error!</code> guard (mutually-exclusive features) — not a defect
<code>cargo check --workspace</code>	0	Compiles clean, 1m52s
<code>cargo-audit audit</code>	0	0 CVE-grade vulnerabilities; 33 allow-listed warnings, 12 of which are “unsound” (not merely unmaintained/yanked)
<code>forge test --summary (X3-contracts/evm)</code>	0	169 passed, 0 failed, 0 skipped, 12 suites
<code>grep -rL "fn benchmarks" → then benchmarks!</code>	—	5 pallets have real FRAME benchmarks
<code>grep -rH "^#[test]" across core dirs</code>	—	1,160 unit-test annotations
<code>git log --all -- sepolia-deployer-wallet.txt / validator summary files</code>	—	2 commits each still reference these paths in history
<code>git check-ignore -v on .suri key files</code>	0	Currently gitignored, not tracked in the working tree
<code>python3 -m py_compile scripts/testnet/run-mesh.py</code>	0	Valid Python

Appendix B — Assumptions, Limitations, and Unknowns Requiring Operator Confirmation

- No independent re-execution of the multi-validator mesh test, the cross-VM router’s named test suite, the supply-ledger invariant tests, or the reconciliation halt tests — all cited as static/artifact evidence only.
- `apps/wallet`’s real signing path was not conclusively traced; marked BLOCKED, not confirmed either way.
- SVM/Bitcoin bridge verifier classes (`SolanaFinalizedVerifier`, `BitcoinSpvVerifier`) were not read this session with the same depth as the EVM receipt verifier; do not assume parity.
- The `launch-gates/embarrassment-suppressions.conf` file was not audited entry-by-entry for continued validity.
- This audit’s overall score (63/100) is a simple unweighted mean, disclosed as such — treat it as directional, not certified.

Appendix C — Regeneration

See the accompanying `README.md` in this output directory for the exact command to regenerate this PDF from source (`typst compile source/report.typ X3-ROAD-TO-MAINNET.pdf`), and `manifest.json` for file checksums and provenance.